

Обход каталога

Описание проблемы

Обход каталога (Path traversal) – это уязвимость, которая возникает из-за того, что входные данные не валидируются, и после этого попадают в функции/методы, взаимодействующих с файловой системой. Благодаря такой уязвимости, злоумышленник может получить доступ к любому файлу на сервере.

В Python с файловой системой взаимодействуют следующие методы:

- методы модуля `os`: `chdir`, `listdir`, `makedirs`, `mkdir`, `rename`, `removedirs`, `replace`
- встроенная функция для работы с файлами `open()`
- `tarfile.open.extractall()`
- `tarfile.open.extract()`

Последствия эксплуатации

Злоумышленник может манипулировать различными вариациями специфичных для файловой системы символами (например, `"../"`) и получить доступ ко всем файлам сервера. Классическим примером является возможность доступа к файлу `/etc/passwd`.

Таким образом, атакующий может получить доступ к критичным для бизнеса данным, манипулировать ими или удалить их.

Пример небезопасного кода

Используется Python-библиотека `os`:

```
1 dist_dir = params.Get('path')
2
3 my_dir = os.path.join(dist_dir, 'key_protect')
4 os.makedirs(my_dir)
```

Пример с `tarfile`

```
1 path = params.Get('path')
2
3 tar_file = tarfile.open(filename, 'r|gz')
4 tar_file.extract_all(path)
5 image_file = tar_file.get_names()[0]
6 tar_file.close()
7
8 os.path.join(path, image_file)
```

Злоумышленник может воспользоваться тем, что входной параметр не фильтруется и создать файл за пределами текущего каталога.

Как исправить?

Лучший способ – использовать белые списки.

Белый список – это конечный список всех значений, которые вы, как разработчик, считаете легитимными для использования программой. Например, вы точно знаете, с какими файлами будет взаимодействовать программа. Тогда вы можете составить список этих расположений и проверять, что путь файла, сформированный с помощью входных параметров, входит в белый список.

Пример безопасного кода

```
1 whitelist_paths = ('path1', 'path2', 'path3')
```

```
2
3 path = params.Get('path')
4
5 if path in whitelist_paths:
6     tar_file = tarfile.open(filename, 'r|gz')
7     tar_file.extract_all(path)
8     image_file = tar_file.get_names()[0]
9     tar_file.close()
```

Дополнительно

1. Проверяйте, что передаваемый путь не выходит за пределы нужного каталога с помощью методов **commonprefix** и **realpath** модуля `os.path`.
2. Убедитесь, что у исполняемого кода ограничены полномочия. Таким образом, программа сможет создавать/изменять файлы только там, где у нее есть доступ.

Альтернативные способы

Если вы не можете использовать белый список (например, он получается бесконечно большим), то необходимо фильтровать специальные символы. Лучше всего допускать ввод только цифр и букв алфавита.

Полезные ссылки

1. [Path Traversal](#)
2. [Python tarfile directory traversal](#)